

Privacy and Security

CompTIA SecAI+: AI Security Certification Complete Exam Prep 2026 | Section 24: Responsible AI

1. The Samsung ChatGPT Incident — Privacy Failure Without a Breach

In March 2023, employees at Samsung's semiconductor division pasted proprietary source code into ChatGPT to assist with debugging. Samsung discovered the data was potentially used to train future models. No external attacker was involved. No credential was stolen. Employees with legitimate access made plausible decisions about tool use—and created a material privacy incident in the process.

This incident illustrates the defining characteristic of AI-related privacy risk: it frequently arises from normal operations rather than adversarial exploitation. The gap was not in perimeter security or access controls—it was in data governance. Employees had no framework for assessing what data was appropriate to share with AI tools versus what should have been sanitized or kept internal. AI privacy risk management must address ordinary, well-intentioned behavior, not only malicious actors.

Real-World Incident — Samsung / ChatGPT (2023): Samsung employees in three separate incidents pasted proprietary source code and internal meeting notes into ChatGPT. Samsung confirmed the data may have been used for model training. Samsung banned generative AI tools company-wide within weeks and began developing an internal AI system. The incident became the canonical example of how AI tool adoption outpaces data governance frameworks.

2. Core Privacy Principles Applied to AI Systems

The data protection principles established by GDPR—incorporated in varying forms across global privacy regulations—apply directly to AI systems and create specific obligations for AI deployment.

GDPR Principle	Application to AI Systems
Purpose Limitation	AI should use data only for the purpose for which it was collected. Using customer service transcripts to train a marketing model without separate consent likely violates this principle.
Data Minimization	Collect and retain only data necessary for the specific AI task. Models should use only features necessary for the prediction, removing sensitive attributes not required for accuracy.
Storage Limitation	Establish and enforce retention policies for training data, model inputs, and model outputs. Models do not inherit the training data's retention policy automatically.
Accuracy	Maintain mechanisms to correct inaccurate data used in AI decisions. Inaccurate training data produces systematically biased outputs.
Accountability	Demonstrate compliance through documented governance—data processing records, impact assessments, model documentation.

A critical insight: the model itself is a data artifact with privacy implications that do not disappear when the training data is deleted. Information encoded in model weights can persist and potentially be extracted through technical attacks, even after source data is removed.

3. AI-Specific Privacy Risks

AI systems introduce privacy risks that do not exist in conventional software. Practitioners must understand these attack classes to assess AI deployments accurately.

- **Memorization:** Large language models can memorize and reproduce verbatim training data, including personal information. Carlini et al. demonstrated extraction of email addresses, phone numbers, and PII from GPT-2 by crafting specific prompts.
- **Membership Inference:** Attackers determine whether a specific individual's data was in a model's training set by analyzing output patterns for inputs related to that individual. This reveals participation in sensitive datasets.
- **Model Inversion:** Attackers reconstruct approximations of training data from model parameters or outputs, potentially recovering sensitive training examples.
- **Training Data Extraction:** By crafting specific prompts, attackers have successfully extracted verbatim training content from LLMs—PII, copyrighted text, confidential data—when that content was present in training data.
- **Secondary Use Leakage:** Models trained for one purpose may reveal information useful for another. A credit risk model may implicitly encode sensitive health information if health-correlated variables were present in training data.

Exam Tip: These AI-specific attack classes are distinct from conventional application security threats. Practitioners who have not updated their threat models for AI are missing an entire attack surface category.

4. Privacy-Preserving Training Techniques

Technical approaches exist to reduce privacy risk during model training. Each involves a privacy-utility trade-off that practitioners must evaluate for specific use cases.

Technique	How It Works	Trade-off / Notes
Differential Privacy (DP)	Adds calibrated mathematical noise to training, providing a formal guarantee that individual data presence has bounded influence on model outputs	DP models typically have lower accuracy, especially for underrepresented groups. Apple and Google deploy DP in production.
DP-SGD	Applies differential privacy to neural network training via differentially private stochastic gradient descent	Implemented in TensorFlow Privacy and Opacus (PyTorch). Computational overhead is significant at scale.
Federated Learning	Trains models across distributed devices without centralizing raw data — only model gradients or	Google uses federated learning for Gboard next-word prediction. Gradient leakage attacks can partially

	parameters are shared	recover training data.
Secure Multi-Party Computation	Enables collaborative training across organizations without any party revealing raw data to others	High computational cost limits practical adoption. Most mature in specific domains like healthcare consortia.

5. Data Minimization in AI Pipelines

Data minimization is simultaneously a privacy principle and a security principle: more data creates larger attack surface. In AI pipelines, minimization operates at multiple stages:

- **Feature Selection:** Use only features necessary for the prediction task. Remove sensitive attributes—race, health status, religion—that correlate with but are not required for the prediction. This reduces both privacy risk and proxy discrimination risk.
- **Training Data Curation:** Remove or aggregate PII from training data before training where possible. Anonymization of training data reduces but does not eliminate re-identification risk.
- **Retention Policies:** Establish and enforce policies for how long training data, model inputs at inference time, and model outputs are retained. Infinite retention of inference-time inputs creates a large PII repository.
- **Access Control:** Limit who can access raw training data, processed features, model parameters, and inference-time inputs. These have different sensitivity profiles and require different access governance.

The Samsung incident illustrates minimization failure at the inference stage: employees had no framework for determining what data was necessary to share with an AI tool versus what should have been sanitized or withheld before using it.

6. AI-Specific Security Attack Classes

Beyond privacy attacks that extract information, AI systems face security attacks targeting system integrity and availability.

- **Data Poisoning:** Corrupts training data to compromise model behavior, the AI equivalent of supply chain attack. Can introduce backdoors, reduce accuracy on targeted inputs, or bias predictions toward attacker-desired outcomes.
- **Adversarial Examples:** Craft inputs with imperceptible perturbations causing confident misprediction at inference time. Applicable to image classifiers, text models, and other modalities.
- **Model Theft (MITRE ATLAS ML.ATLAS.006):** Queries a deployed model extensively to reconstruct a functional replica, enabling targeted adversarial attack development and bypassing access controls on the original model.
- **Prompt Injection (OWASP LLM01):** Injects adversarial instructions into LLM inputs through user-controlled content, causing the model to override system instructions or perform unintended actions.

- **Inference API Abuse:** Uses AI inference APIs for unintended purposes — generating phishing content through a customer service chatbot, bypassing content filters, or extracting proprietary model behavior.

7. Security Requirements Specific to AI Systems

AI systems have security requirements that extend conventional application security practices.

- **Model Integrity:** Model parameters should be cryptographically protected against unauthorized modification. Model tampering—altering weights to change behavior—is an attack vector in deployed systems.
- **Inference API Security:** AI inference APIs require authentication, rate limiting, and abuse prevention controls. Unauthenticated inference APIs are a common and high-risk misconfiguration in early AI deployments.
- **Training Infrastructure Security:** The training pipeline—data ingestion, preprocessing, training execution, model artifact storage—presents attack surface for supply chain compromise. Each stage requires integrity controls.
- **Output Security:** AI-generated content should be treated as untrusted external input. Do not execute AI-generated code without review. Model files from public repositories can be malicious; artifact scanning is a necessary control.

Real-World Incident — Malicious Model Files on Hugging Face (2023-2024): Researchers identified hundreds of malicious model files uploaded to Hugging Face's model hub, some capable of executing arbitrary code when loaded using standard PyTorch or pickle deserialization. Organizations downloading pre-trained models without scanning faced supply chain compromise risk comparable to malicious packages in code repositories. This established model artifact scanning as a security control requirement for AI pipelines consuming community models.

8. Third-Party AI Governance — Supply Chain Security for AI

Organizations integrating third-party AI tools—LLM APIs, pre-trained models from public repositories, specialized AI applications—inheriting privacy and security risks from those tools. Key governance requirements:

- Establish approved AI tool lists with formal evaluation criteria before tools enter production use — the Samsung incident resulted from employees using unevaluated public tools.
- Understand data handling terms: does the provider use your inputs for training? What data residency requirements apply? What are the terms if the provider is acquired or changes policy?
- Evaluate models from public repositories for security: verify provenance, scan model artifacts for known malicious indicators, and review the repository contributor history.
- Apply supply chain security thinking to AI: model repositories are analogous to package registries; the same trust and verification disciplines apply.

Third-party AI governance is not a new category of risk management—it is supply chain security applied to machine learning. Organizations that have mature software supply chain practices should extend those practices to AI artifacts rather than treating AI as categorically different.

9. Regulatory Landscape for AI Privacy

Framework	Key AI Privacy Provisions
GDPR (EU)	Article 22: rights regarding automated decisions; Articles 5-6: lawful processing and purpose limitation; Articles 13-15: transparency and access rights
EU AI Act (2024)	Adds AI-specific requirements on top of GDPR including data governance documentation for high-risk AI training data
CCPA/CPRA (California)	Rights regarding automated decision-making and profiling; opt-out rights for automated decisions
HIPAA (US Healthcare)	Sector-specific protections applying to AI systems processing protected health information
GLBA (US Financial)	Sector-specific protections applying to AI systems in financial services contexts
FERPA (US Education)	Sector-specific protections for student educational records processed by AI systems

Understanding which regulations apply requires knowing the data categories processed, the geographic scope of affected individuals, and the decision context. Privacy counsel involvement in AI deployment decisions is responsible practice. Multiple regulations may apply simultaneously to a single AI system.

10. Privacy Commitments for Practitioners

- Never input personal data—names, email addresses, SSNs, health information, financial details—into AI tools without verifying data handling terms first.
- If in doubt about what to share, anonymize or synthesize data before using AI tools for analysis.
- When using AI for analysis of individual behavior—employee monitoring, customer analytics, fraud detection—ensure a legal basis exists and individuals have appropriate notice.
- **Treat AI tool data exposure as a privacy incident requiring formal response**, not quiet remediation. The Samsung approach—discover, ban, investigate—is the appropriate organizational response, not silent remediation.
- Do not use AI to aggregate data from multiple sources to reconstruct individual profiles that would not be permissible to create through other means.
- Verify that customer-facing AI tools provide appropriate consent disclosure before deployment.

Key Terms Glossary

Term	Definition
Memorization	The phenomenon where LLMs retain and can reproduce verbatim training data, including PII, when prompted appropriately.
Membership Inference	Attack determining whether a specific individual's data was in a model's training set by analyzing model output patterns.
Model Inversion	Attack reconstructing approximations of training data from model parameters or outputs.

Training Data Extraction	Attack using crafted prompts to elicit verbatim reproduction of sensitive training content from a deployed model.
Differential Privacy	Mathematical framework adding calibrated noise to training, providing formal guarantees that individual data presence has bounded model influence.
DP-SGD	Differentially private stochastic gradient descent — applies differential privacy to neural network training.
Federated Learning	Training approach distributing computation across devices without centralizing raw data; only model updates are shared.
Data Poisoning	Attack corrupting training data to compromise model behavior — the AI equivalent of software supply chain compromise.
Prompt Injection (LLM01)	Attack injecting adversarial instructions into LLM inputs through user-controlled content to override system instructions.
Model Theft (ATLAS ML.ATLAS.006)	Attack querying a deployed model extensively to reconstruct a functional replica for targeted adversarial exploitation.
Purpose Limitation	GDPR principle requiring data to be used only for the purpose for which it was collected.
Data Minimization	GDPR principle requiring collection and retention of only data necessary for the specific task.

Quick Revision Checklist

- Samsung ChatGPT (2023): the canonical AI privacy incident from normal operations, not malicious actors — employees pasted proprietary code into a public LLM.
- Core GDPR principles applying to AI: purpose limitation, data minimization, storage limitation, accuracy, accountability.
- AI-specific privacy risks: memorization, membership inference, model inversion, training data extraction, secondary use leakage.
- Privacy-preserving training: differential privacy (formal guarantee, accuracy cost), federated learning (no data centralization), DP-SGD (neural network DP).
- Data minimization applies at four pipeline stages: feature selection, training data curation, retention policies, and access control.
- AI-specific security attack classes: data poisoning, adversarial examples, model theft (ATLAS ML.ATLAS.006), prompt injection (OWASP LLM01), inference API abuse.
- Model integrity, inference API security, training infrastructure security, and output security are AI-specific security requirements.
- Malicious model files on Hugging Face (2023-2024) established model artifact scanning as a required supply chain security control.
- Third-party AI governance is supply chain security applied to ML — approved tool lists, data handling verification, model artifact scanning.
- The model is itself a data artifact: privacy risks encoded in weights persist even after training data is deleted.

10 Exam-Based MCQs — Privacy and Security in AI

Test yourself after reading. These questions are written in real exam style — scenario-heavy, with plausible distractors. Read every explanation, including for questions you answered correctly.

Q1. *Scenario:* Samsung semiconductor employees pasted proprietary source code into ChatGPT to assist with debugging. Samsung discovered the data may have been used for model training and banned generative AI tools company-wide within weeks. Which data governance failure MOST directly caused the Samsung ChatGPT privacy incident?

- A) Absence of perimeter security controls preventing external access to Samsung's network
- B) Absence of a framework for employees to assess what data was appropriate to share with third-party AI tools
- C) Absence of encryption on the proprietary source code files
- D) Absence of multi-factor authentication on Samsung developer accounts

Answer: B **Explanation:** B is correct — the incident occurred because employees made plausible decisions about using legitimate tools without any framework for determining data appropriateness. No attacker was involved; no credential was compromised. The gap was in data governance, specifically the absence of guidance on AI tool data handling. A is wrong because the incident did not involve an external network intrusion. C is wrong because file encryption was irrelevant — the employees had legitimate access to the code. D is wrong because authentication controls were not the failure point; authorized users made the disclosure.

Q2. A researcher queries an AI model with hundreds of carefully crafted prompts related to a specific individual and successfully determines that person's data was used in model training. Which AI-specific privacy attack has occurred?

- A) Model inversion
- B) Training data extraction
- C) Membership inference
- D) Adversarial example generation

Answer: C **Explanation:** C is correct — membership inference determines whether a specific individual's data was in a model's training set by analyzing model output patterns for inputs related to that individual. A is wrong because model inversion reconstructs approximations of training data from model parameters or outputs — recovering actual training examples, not determining membership. B is wrong because training data extraction involves eliciting verbatim reproduction of training content through prompts — not merely inferring that content existed. D is wrong because adversarial examples are crafted inputs causing misprediction, not attacks that determine training set membership.

Q3. Which privacy-preserving training technique provides a formal mathematical guarantee that the presence or absence of any individual's data has bounded influence on model outputs?

- A) Federated learning
- B) Secure multi-party computation

- C) Differential privacy
- D) Data anonymization before training

Answer: C **Explanation:** C is correct — differential privacy is specifically defined by the formal guarantee that individual participation has epsilon-bounded influence on model outputs. This is a mathematical property, not a best-effort practice. A is wrong because federated learning prevents data centralization but does not provide formal privacy guarantees — gradient leakage attacks can partially recover training data from shared gradients. B is wrong because secure multi-party computation enables collaborative training without revealing data to other parties but does not provide the specific individual-influence bound that differential privacy does. D is wrong because anonymization reduces re-identification risk but does not provide formal mathematical guarantees about model output influence.

Q4. A security team discovers that a model artifact downloaded from a public AI repository executes arbitrary code when loaded. Which security control would MOST directly have prevented this incident?

- A) Inference API rate limiting
- B) Model integrity verification and artifact scanning before loading repository models
- C) Differential privacy applied to model training
- D) Federated learning to avoid model centralization

Answer: B **Explanation:** B is correct — malicious model files embedded in public repositories (demonstrated on Hugging Face in 2023-2024) execute during deserialization when loaded. The preventive control is scanning model artifacts for malicious indicators and verifying provenance before loading, analogous to package integrity verification in software supply chain security. A is wrong because rate limiting addresses API abuse, not malicious model file execution. C is wrong because differential privacy is a training technique protecting individual data privacy, not a control against malicious artifacts. D is wrong because federated learning distributes training computation but does not prevent loading of malicious model artifacts.

Q5. An organization uses a third-party LLM API for customer service automation. Customers' personal data is processed during inference. Under GDPR, which principle requires the organization to verify that the LLM provider does not use customer inputs for model training without separate legal basis?

- A) Data minimization
- B) Purpose limitation
- C) Storage limitation
- D) Accuracy

Answer: B **Explanation:** B is correct — purpose limitation requires that personal data be used only for the purpose for which it was collected. Customers provided data for customer service interactions; using that data to train future models is a different purpose requiring a separate legal basis. A is wrong because data minimization addresses the quantity of data collected and retained, not the secondary uses of data. C is wrong because storage limitation addresses retention periods, not secondary use for training. D is wrong because accuracy addresses correctness of data, not secondary use.

Q6. MITRE ATLAS ML.ATLAS.006 describes which AI security attack?

- A) Data poisoning — corrupting training data to compromise model behavior
- B) Prompt injection — injecting adversarial instructions through user-controlled LLM inputs
- C) Model theft — querying a deployed model to reconstruct a functional replica
- D) Membership inference — determining whether an individual's data was in training data

Answer: C **Explanation:** C is correct — MITRE ATLAS ML.ATLAS.006 specifically describes model theft (also called model extraction or model stealing), where an attacker queries a deployed model extensively to reconstruct a functional replica. This enables targeted adversarial attacks against the replica and bypasses access controls on the original model. A is wrong because data poisoning is a different attack class — it corrupts training rather than stealing the trained model. B is wrong because prompt injection is classified under OWASP LLM Top 10 LLM01, not MITRE ATLAS ML.ATLAS.006. D is wrong because membership inference is a separate privacy attack class, not ML.ATLAS.006.

Q7. Which statement BEST describes why deleting training data does not fully eliminate the privacy risk encoded in a trained AI model?

- A) Regulatory frameworks require retaining training data for audit purposes, preventing deletion
- B) Model parameters encode patterns from training data and can be exploited through memorization, membership inference, and model inversion attacks even after the source data is deleted
- C) Trained models automatically retain backup copies of training data in their storage infrastructure
- D) Deleting training data requires retraining the model from scratch, making deletion practically infeasible

Answer: B **Explanation:** B is correct — this is the core insight that model weights are themselves data artifacts with privacy implications. Information encoded in model parameters persists and can be extracted through technical attacks (memorization, membership inference, model inversion) independent of whether the original training data exists. A is wrong because regulatory retention requirements are a separate consideration, not the reason deletion fails to eliminate privacy risk. C is wrong because trained models do not automatically retain training data backups — this mischaracterizes how model storage works. D is wrong because deletion is technically feasible; the issue is that deletion of training data does not remove the information encoded in already-trained model parameters.

Q8. An AI pipeline uses customer transaction data to detect fraud. Feature engineering creates 47 variables from raw transactions. The security review recommends removing 12 variables related to health-correlated purchase categories. Which principle MOST directly supports this recommendation?

- A) Storage limitation — the variables should be retained for shorter periods
- B) Accuracy — removing variables will improve model accuracy
- C) Data minimization — sensitive attributes not necessary for the prediction should be excluded
- D) Purpose limitation — health-related data cannot be used for fraud detection under any circumstance

Answer: C **Explanation:** C is correct — data minimization applied to feature selection means removing

sensitive attributes that are not necessary for the prediction task. Health-correlated purchase variables create privacy risk and proxy discrimination risk without being required for fraud detection. A is wrong because storage limitation addresses retention duration, not feature selection. B is wrong because removing sensitive features may or may not improve accuracy — the recommendation is driven by privacy and governance principles, not accuracy improvement. D is wrong because purpose limitation addresses secondary uses of data, and health-correlated purchase data may have a valid basis for processing in fraud contexts — the principle applying here is minimization, not an absolute prohibition.

Q9. Which of the following BEST describes the privacy-utility trade-off specific to differential privacy in AI model training?

- A) Differential privacy increases model accuracy by removing noise from training data
- B) Differential privacy models typically have lower accuracy than non-private models, with the accuracy penalty being larger for underrepresented groups
- C) Differential privacy eliminates all re-identification risk in model outputs at negligible accuracy cost
- D) Differential privacy applies only to tabular data models; it cannot be applied to neural networks

Answer: B **Explanation:** B is correct — the privacy-utility trade-off for differential privacy is well-established: adding noise reduces model accuracy, and this accuracy penalty is disproportionately larger for underrepresented groups because the model has less data to 'average out' the noise for minority subgroups. This creates an equity concern alongside the accuracy cost. A is wrong because differential privacy adds noise, it does not remove it — accuracy decreases, not increases. C is wrong because differential privacy provides a bounded mathematical guarantee, not elimination of all re-identification risk, and the accuracy cost is real and significant at strong privacy guarantees. D is wrong because DP-SGD applies differential privacy to neural network training and is implemented in TensorFlow Privacy and Opacus.

Q10. *Scenario:* A large enterprise wants to deploy an AI system that analyzes employee email and Slack communications to identify potential insider threats. The security architecture team is designing the governance framework for the deployment. A security architect is designing an AI system for analyzing employee communications to detect insider threats. Which combination of requirements MOST comprehensively addresses both privacy and security obligations?

- A) Deploy with default AI tool settings and inform the legal team after deployment
- B) Establish lawful processing basis, provide employee notice, apply data minimization to features, implement inference API security, and maintain audit logs of AI-influenced decisions
- C) Use federated learning exclusively, which eliminates all privacy obligations by avoiding data centralization
- D) Apply differential privacy to model training, which satisfies all regulatory requirements for insider threat detection

Answer: B **Explanation:** B is correct — insider threat detection AI processing employee communications requires: a lawful basis under GDPR or equivalent (typically legitimate interest with a balancing test); employee notice under multiple privacy frameworks; data minimization to limit feature sensitivity;

inference API security given the sensitive nature of the system; and audit trails for accountability and forensic investigation. This combination addresses both the privacy compliance framework and the security requirements for a sensitive AI deployment. A is wrong because post-deployment legal notification is not a governance approach — it's remediation of a governance failure. C is wrong because federated learning prevents data centralization but does not eliminate privacy obligations; lawful basis, notice, and other requirements still apply. D is wrong because differential privacy addresses training data privacy but does not satisfy all regulatory requirements — lawful basis, employee notice, and operational controls are still required.